



T.C.

**BANDIRMA ONYEDİ EYLÜL ÜNİVERSİTESİ
MÜHENDİSLİK VE DOĞA BİLİMLERİ
FAKÜLTESİ**

2026 - 2027 Eğitim Öğretim Yılı

The background of the page features a technical drawing of mechanical parts, including gears and a cross-section of a component with dimensions like R1, P20, and 100.

STAJ DEFTERİ

ADI-SOYADI : Gaye Nur Güneş

ÖĞRENCİ NUMARASI : 2211502017

BÖLÜMÜ : Bilgisayar Mühendisliği



T.C.
BANDIRMA ONYEDİ EYLÜL
ÜNİVERSİTESİ MÜHENDİSLİK VE
DOĞA BİLİMLERİ FAKÜLTESİ



ÖĞRENCİ BİLGİLERİ

Adı Soyadı	:	Gaye Nur Güneş
Öğrenci Numarası	:	2211502017
Bölümü	:	Bilgisayar Mühendisliği
Staj Dönemi	:	☒ Staj -1 ☐ Staj -2 ☐
Yaptığı Staj Dalı	:	Siber Güvenlik
Telefon/ e-posta	:	05392277300 / gayenur467@gmail.com

KURUM BİLGİLERİ

İş Yeri Adı	:	Bimser Çözüm Yazılım Tic. A.Ş.
Adresi	:	Yeniköy Merkez Mah. Vatan Cad. No: 73D İç Kapı No: 305, KOÜ Teknopark, Başiskele / Kocaeli
Telefon / e-posta	:	(262) 341-43-14 / bimser@bimser.com.tr
Staj Başlama Tarihi	:	24 / 08 / 2026
Staj Bitiş Tarihi	:	18 / 09 / 2026
Staj Süresi (gün)	:	20

İşveren veya Yetkilinin

Adı Soyadı:

İmzası ve Kaşe

Gün	24.08.2026 -28.08.2026	Sayfa No
Pazartesi	NIST Olay Müdahale Yaşam Döngüsü (4 aşama), Case 1 sunum	5
Salı	Playbook kavramı, korelasyon için SPL (timechart, rex)	6
Çarşamba	IOC, Pyramid of Pain, MITRE ATT&CK teknik eşlemesi	7
Perşembe	Case 2: mshta, LOLBin, lsass, DNS tünelleme analizi	8
Cuma	Case 2: PID zinciri doğrulama, persistence, lateral movement	9

Gün	31.08.2026 -04.09.2026	Sayfa No
Pazartesi	SPF/DKIM, masquerading, negatif kanıt, görünürlük boşluğu	10
Salı	Case 2 olay raporu: özet, kapsam, zaman çizelgesi	11
Çarşamba	Case 2 olay raporu: bulgular, kanıtlar, öneriler	12
Perşembe	Mandiant, SolarWinds, FIN7 attribution metodolojisi	13
Cuma	Hafta 6 değerlendirme raporu (Case 1 vs Case 2), Case 2 sunum	14

Gün	07.09.2026 -11.09.2026	Sayfa No
Pazartesi	SOC nedir, SOC katmanları, Event/Alert/Triage	15
Salı	Alarm kuyruğu triyajı (9 alarm)	16
Çarşamba	Gerçek phishing e-postaları analizi (3 örnek)	17
Perşembe	Malware statik analizi (AgentTesla), YARA kuralı	18
Cuma	Sigma kuralları, tespit mühendisliği	19

Gün	14.09.2026 -18.09.2026	Sayfa No
Pazartesi	Case 3: phishing e-postası ve zararlı ISO eki (YARA kuralı)	20
Salı	Case 3 Olay Raporu: Yönetici Özeti ve Teknik Ek	21
Çarşamba	Tespit Kuralları Deposu (Tespit-Kurallari/)	22
Perşembe	Repo README'si ve Portfolyo Düzenlemesi	23
Cuma	Pusula: Stajdan Çıkarımlar ve Sonraki Adımlar	24

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 24.08.2026 (Pazartesi)
<u>Yapılan iş:</u> NIST Olay Müdahale Yaşam Döngüsü ve Case 1 Sunumu		
Staj 2'nin ilk günü NIST Olay Müdahale Yaşam Döngüsü'nü (NIST SP 800-61) çalıştım. Bu döngünün bir olayın tespitinden kapanışına kadar geçen süreci dört aşamaya ayırdığımı, ancak bu aşamaların birbirini takip eden kopuk kutular değil, sık sık geri dönülen birbirini besleyen bir akış olduğunu öğrendim. Hazırlık (Preparation) aşamasının, bir olay gerçekleşmeden önce yapılan log toplama altyapısı, SIEM kurulumu, playbook'lar ve ekip yetkilerinin tanımlı olması gibi çalışmaları kapsadığını; bu aşama zayıfsa geri kalan üç aşamanın hiçbirinin mümkün olmadığını kavradım. Tespit ve Analiz (Detection & Analysis) aşamasının, bir sapmanın fark edilmesi ve bu sapmanın kanıtlarla bir olay hikayesine dönüştürülmesi olduğunu; Case 1'deki beş bulgumun tam olarak bu aşamanın çıktısı olduğunu gördüm. Sınırlama, Yok Etme, Kurtarma (Containment, Eradication, Recovery) aşamasının üç alt adımını Case 1 üzerinden somutlaştırdım: parola değiştirme ve IP engelleme (containment), sahte hesabın silinmesi (eradication), anahtar tabanlı kimlik doğrulamaya geçiş (recovery). Son olarak Olay Sonrası (Post-Incident) aşamasının, 'bu neden mümkün oldu, bir daha olmasın' sorusuna cevap arayan değerlendirme olduğunu kavradım. Ayrıca bu gün, staj 1 sürecinde hazırladığım Case 1 olay raporunu sunduğum bir sunum gerçekleştirdim. Vakayı bir zaman çizelgesi üzerinden anlattım: dış bir IP'den gelen sistematik brute force denemelerinden, deploy hesabına başarılı girişten, hemen ardından /etc/shadow dosyasının okunmasından ve yeni bir kullanıcı oluşturulmasına kadar tüm olay zincirini adım adım aktardım. Teknik detaylara (SPL sorguları, log alanları gibi) girmeden bunları üstten özetleyip asıl vurguyu olayların akışına verdim; sunumu etki değerlendirmesi ve önerilerle (parola politikası, IP kısıtlaması, anahtar tabanlı kimlik doğrulama gibi) tamamladım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		5

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 25.08.2026 (Salı)
<u>Yapılan iş:</u> Playbook ve Korelasyon için SPL		
İkinci günümde playbook kavramını ve korelasyon için kullanılan SPL komutlarını çalıştım. Playbook'un, belirli bir olay türünde izlenecek adımların önceden yazılmış hali olduğunu; analiz anındaki zaman baskısında sezginin adım atlamaya yol açabileceğini, playbook'un bu tutarsızlığı azalttığını öğrendim. 'Şüpheli giden trafik alarmı' için örnek bir playbook'u (kaynak/hedef doğrulama, geçmiş trafik kontrolü, tehdit istihbaratı kontrolü, containment veya kapatma kararı) adım adım inceledim. Korelasyon için üç SPL aracını çalıştım: timechart'ın 'ne zaman oldu' sorusunu cevapladığını, sabit yoğunluktaki bir saldırı deseninin insan davranışından ayırt edilmesini sağladığını gördüm. rex komutunun, ham log metninden bir alanı Splunk'ın anlayabileceği yapılandırılmış bir alana çevirdiğini kavradım. Son olarak çok kaynaklı aramanın iki log kaynağını zaman sırasına göre birlikte gösterdiğini, ancak aralarında otomatik bir bağlantı kurmadığını; gerçek bağlantının ortak bir alan üzerinden stats by veya transaction ile kurulması gerektiğini öğrendim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		6

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 26.08.2026 (Çarşamba)
<u>Yapılan iş:</u> IOC ve MITRE ATT&CK Teknik Eşlemesi		
Üçüncü günümde IOC (Indicator of Compromise) kavramını ve MITRE ATT&CK teknik eşlemesini çalıştım. IOC'nin bir saldırının gerçekleştiğine dair somut ve aranabilir bir iz olduğunu; Case 1'in IOC listesini (203.0.113.66, deploy, svc-update) çıkararak bu göstergelerin tüm ortamda nasıl aranabilir hale geldiğini gördüm. David Bianco'nun Pyramid of Pain kavramını inceledim: piramidin altındaki IP/alan adı gibi göstergelerin saldırgan tarafından kolayca değiştirilebildiğini, en tepedeki davranış/teknik (TTP) göstergelerinin ise değiştirilmesinin çok daha maliyetli olduğunu kavradım. Bu yüzden hem IOC hem de MITRE ATT&CK tekniklerinin birlikte kullanılması gerektiğini öğrendim. Case 1'in dört adımını MITRE ATT&CK teknikleriyle eşleştirdim: Brute Force (T1110), Valid Accounts (T1078), OS Credential Dumping (T1003.008), Create Account (T1136.001). Son olarak çok kaynaklı iz sürme mantığını; bir kaynakta bulunan bir göstergenin diğer kaynağa açılan bir kapı niteliğinde olduğunu kavradım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		7

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 27.08.2026 (Perşembe)
<u>Yapılan iş:</u> Case 2: İlk İnceleme(mshta, LOLBin, DNS Tünelleme)		
Dördüncü günümde Case 2 adlı yeni ve çok daha karmaşık bir olayı incelemeye başladım. mshta.exe'nin meşru bir Windows sistem programı olduğunu ama LOLBin olarak kötüye kullanılabildiğini; lsass.exe'ye erişimin genelde kimlik bilgisi hırsızlığı girişimi olduğunu öğrendim. DNS tünellemenin, verinin bir DNS sorgusunun subdomain kısmına kodlanarak gönderilmesi olduğunu; rastgele bir subdomain + TXT sorgusu + NXDOMAIN cevabının bu tekniğin tipik imzası olduğunu kavradım. OBSERVED/INFERRED/UNKNOWN kanıt sınıflandırmasını uyguladım: firewall logunda 192.168.20.45'in olağandışı giden trafiğini doğruladım, DNS logunda bu trafiğin static-cdn-analytics.com'a (45.137.21.88) gittiğini ve hex-subdomain + TXT + NXDOMAIN deseni bulunduğunu gördüm. Sysmon'da bu bağlantıyı açan sürecin powershell.exe olduğunu tespit ettim. Bulgularımdan bir senaryo kurdum (henüz INFERRED): sahte bir fatura ekinin (Fatura_2026_4471.docm) açılması, makronun mshta.exe üzerinden internete çıkması, static-cdn-analytics.com'dan dosya indirilmesi ve muhtemelen kimlik bilgisi hırsızlığı girişimi. Bu, tek taktikli Case 1'in aksine çok aşamalı bir saldırı zincirinin ilk günüydü.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		8

<u>İş Yerinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 28.08.2026 (Cuma)
<u>Yapılan iş:</u> Case 2: PID Zinciri Doğrulama ve Lateral Movement		
Beşinci günümde Case 2'nin PID zincirini kesinleştirdim. Sysmon'da ProcessId/ParentProcessId alanlarını izleyerek explorer.exe - WINWORD.EXE - mshta.exe - powershell.exe - svchost_update.exe - m.exe zincirini PID eşleşmesiyle doğruladım; lsass erişiminde GrantedAccess=0x1410'un klasik bir credential-dumping imzası olduğunu ve bunun m.exe'nin PID'siyle eşleştiğini gördüm. Böylece zincir INFERRED'dan OBSERVED'a yükseldi. Persistence sorusunu EventCode=4698 (scheduled task oluşturma) ile araştırdım; bulduğum görevin base64 kodlu içeriğinin aynı domainden b.exe indirip svchost_update.exe adıyla çalıştırdığını, yani PID zincirindeki isimle birebir örtüştüğünü gördüm. SubjectUserName=b.kaya'nın görevi oluşturan hesap olduğunu, ancak bunun kasıtlı mı yoksa ele geçirilmiş bir oturum üzerinden mi olduğunun ayrı bir soru olduğunu kavradım. Son olarak lateral movement sorusunu auth.log'da app-db01 üzerinde araştırdım: svc-backup hesabının FIN-WS03'ün IP'sinden parola ile giriş yaptığını, hemen ardından sudo ile müşteri veritabanını bir arşive sıkıştırdığını buldum. Bunu aynı hesabın normal, farklı IP'den ve publickey ile yapılan girişiyle karşılaştırarak anormalliği kanıtladım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		9

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 31.08.2026 (Pazartesi)
<u>Yapılan iş:</u> Case 2: SPF/DKIM, Masquerading ve Görünürlük Boşlukları		
Altıncı günümde SPF ve DKIM kavramlarını, masquerading tekniğini ve negatif kanıt/görünürlük boşluğu kavramlarını çalıştım. SPF'in bir domainin hangi sunucuların onun adına mail gönderebileceğini tanımladığını, DKIM'in ise maili dijital imza ile doğruladığını; spf=fail ve dkim=none'ın gönderenin taklit edildiğini gösterdiğini öğrendim. Masquerading'in, saldırganın indirdiği bir dosyaya meşru bir sistem dosyasının adını vermesi olduğunu kavradım. Negatif kanıt kavramının, bir olayın olmadığını gösteren kanıt biçimi olduğunu; scheduled task'ın oluşturulduğu an başka hiçbir giriş kaydı olmamasının, ayrı bir saldırgan oturumu olmadığını kanıtı sayıldığını öğrendim. Bu mantıkla mail logunu inceleyip case2:mail kaynağını UNKNOWN'dan OBSERVED'a yükselttim: fatura ekinin gönderildiği IP'nin zaten C2 altyapısıyla aynı olduğunu buldum. Üç ayrı görünürlük boşluğu tespit ettim: scheduled task'ı hangi sürecin tetiklediği, 480 MB'lık transferi hangi sürecin açtığı ve DNS beacon'ının tam profili. Her birini INFERRED olarak işaretleyip hangi ek log kaynağının bunu çözebileceğini not ettim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		10

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 01.09.2026 (Salı)
<u>Yapılan iş:</u> Case 2: Olay Raporu - Özet ve Zaman Çizelgesi		
Yedinci günümde, o zamana kadar Case 2'de topladığım tüm bulguları (mail, DNS, sysmon, winsecurity, auth logları) tek bir olay raporunda birleştirmeye başladım. INC-2026-0914-02 numaralı raporun özet ve kapsam bölümünü, etkilenen sistemleri (FIN-WS03, app-db01) ve hesapları (b.kaya, svc-backup) belirleyerek yazdım. Saldırının teknik zincirinin OBSERVED, kalıcılığı kuran sürecin kimliği ve 480 MB'lık transferin kaynağının ise mevcut log kapsamıyla kesinleştirilemediği için INFERRED seviyesinde bırakıldığını netleştirdim. Detaylı bir zaman çizelgesi tablosu oluşturdum: 08:29'daki normal girişten başlayarak, 09:12'deki spoofed mail girişinden, 09:41'deki WINWORD - mshta - powershell - svchost_update - m.exe zincirine, 10:31'deki lateral movement'a ve 11:20'deki büyük veri transferine kadar tüm olayları saat, kaynak, olay, varlık ve değerlendirme sütunlarıyla sıraladım. Bu çizelgeyi oluştururken farklı log kaynaklarındaki zaman damgalarını tek bir tutarlı akışta birleştirmenin, haftalar boyunca tek tek çalıştığım sorguları bir araya getirmekten çok daha zor olduğunu fark ettim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		11

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 02.09.2026 (Çarşamba)
<u>Yapılan iş:</u> Case 2: Olay Raporu - Bulgular ve Kanıtlar		
Sekizinci günümde raporun bulgular ve kanıtlar bölümünü tamamladım. Beş ana bulguyu ayrıntılandırdım: spoofed fatura maili, execution zincirindeki LOLBin kullanımı ve svchost_update.exe'nin masquerading davranışı, C2/DNS tünelleme beacon profili (32 firewall bağlantısı, 38 düzenli A-record beacon, 4 TXT/NXDOMAIN tünelleme sorgusu), persistence (scheduled task) ve son olarak lateral movement/olası exfiltration. Her bulgu için hangi log kaynağının hangi kanıtı sağladığını ve kanıt seviyesini (OBSERVED/INFERRED) ayrı ayrı belirttim; özellikle 480 MB'lık transferin kaynağının Sysmon'da hiç görünmemesi nedeniyle bunu açık bir görünürlük boşluğu olarak işaretledim. Raporun etki ve öneriler bölümünü yazarak INC-2026-0914-02'yi tamamladım; bu, Case 1'in tek taktikli, düz çizgili yapısının aksine yedi farklı MITRE tekniğini kapsayan çok aşamalı bir olayın uçtan uca raporlanması oldu.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		12

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 03.09.2026 (Perşembe)
<u>Yapılan iş:</u> Mandiant, SolarWinds ve FIN7 Attribution		
Dokuzuncu günümde Mandiant şirketini ve iki önemli okumasını çalıştım. Mandiant'ın 2004'te kurulan, SolarWinds saldırısını ilk tespit eden ve FIN7 gibi tehdit gruplarına isim veren, sektörde referans kabul edilen bir tehdit istihbaratı şirketi olduğunu öğrendim. SolarWinds saldırısının, devlet destekli bir grubun bir yazılımın güncelleme sürecine sızarak yaklaşık 18.000 kurumu etkilemesiyle, imzalı/resmi bir kaynaktan gelmenin otomatik güvenlik anlamına gelmediğini gösteren klasik bir tedarik zinciri saldırısı olduğunu kavradım. Mandiant'ın FIN7 attribution metodolojisini inceledim: bir grubu FIN7'ye dahil etmeden önce dört kanıt katmanının (altyapı, saldırı tekniği, çalışma biçimi, kod kullanımı) örtüşmesini aradıklarını; tek bir örtüşmenin yeterli olmadığını öğrendim. Bu disiplini kendi raporumdaki belirsiz noktalara uyguladım: kesin bir yargı yerine hangi kanıtın eksik olduğunu açıkça belirttim. PowerShell Archaeology okumasında FIN7'nin kendine özgü, nadir görülen komut satırı parametre kombinasyonlarını ve POWERTRASH adlı özelleştirilmiş bir loader'ı kullandığını öğrendim. Kendi bulgumdaki 'powershell.exe encoded komutla başlatıldı' ifademini, tam parametreleri kaydetmediğim için bu düzeyde bir parmak izi sağlamadığını fark ettim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		13

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 04.09.2026 (Cuma)
<u>Yapılan iş:</u> Hafta 6 Değerlendirme Raporu ve Case 2 Sunumu		
Onuncu günümde altıncı haftanın değerlendirme raporunu yazdım. Case 1 ile Case 2'yi karşılaştırdım: Case 1'de elimde numaralandırılmış yedi soru varken, Case 2'de neyi bulmam gerektiğine kendim karar vermek zorunda kaldığımı; Case 1'de tek bir log kaynağı ve tek makine varken, Case 2'de altı farklı kaynağı iki farklı işletim sisteminde birbirine bağlamam gerektiğini yazdım. Ayrıca Case 2'ye ait bir sunum hazırlayıp gerçekleştirdim. Sunumda vakayı bir hikaye gibi kurguladım: sahte fatura ekiyle başlayan ilk erişimden, mshta üzerinden çalıştırılan makrodan, kimlik bilgisi hırsızlığı girişiminden, kalıcılık için oluşturulan zamanlanmış görevden ve olası veri sızıntısıyla sonuçlanan yanal harekete kadar tüm olay zincirini saat saat bir zaman çizelgesi üzerinden aktardım. Teknik detaylara (PID eşleşmeleri, kullanılan komutlar, log alanları gibi) girmek yerine bunları üstten, sonucu değiştiren kritik noktalar olarak özetledim; asıl vurguyu olayların akışına ve birbirini nasıl tetiklediğine verdim. Sunumu, raporumdaki etki değerlendirmesi ve önerilerle (kalıcılık mekanizmalarının temizlenmesi, DNS tünelleme trafiğinin izlenmesi, e-posta doğrulama politikalarının sıkılaştırılması gibi) tamamladım. Saldırının kendisinin de bambaşka olduğunu; Case 1'in tek taktikli düz bir çizgi, Case 2'nin ise yedi farklı MITRE tekniğini kapsayan çok aşamalı bir zincir olduğunu belirttim. Kanıt derecesi kavramının ilk kez Case 2'de gerçek anlamda işime yaradığını; bazı noktaları hiçbir kaynaktan bulamayıp ilk kez gerçek bir görünürlük boşluğu ile karşılaştığımı yazdım. En çok zorlandığım yerin Splunk'ta alan adı uyumsuzlukları olduğunu, bunu ham _raw veriye bakarak aştığımı belirttim. En gurur duyduğum anın, dağınık log kayıtlarının tek bir olay örgüsüne dönüştüğü an olduğunu; bir dahaki vakada ilk gün veri kaynaklarının alan şemasını önce kontrol ederek başlayacağımı yazarak raporu tamamladım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		14

<u>İş Yeri</u>nde Çalışılan Birim: IT Departmanı - Siber Güvenlik Birimi		Tarih: 07.09.2026 (Pazartesi)
<u>Yapılan iş:</u> SOC Kavramı, Katmanları ve Vaka Defteri Şablonu		
On birinci günümde SOC (Security Operations Center) kavramını ve katmanlarını çalıştım. SOC'nin, sınırlı bir küme için siber güvenlik olaylarını önleme, tespit etme, analiz etme, cevap verme ve raporlama görevini üstlenen organize bir ekip olduğunu; NOC'tan, CISO/CIO'dan ve kolluk kuvvetlerinden ayrıldığını öğrendim. SOC katmanlarını inceledim: L1 analistlerin gelen alarm akışını karşılayıp hızlı triyaj yaptığını, L2/L3'ün ise daha derin analiz ve adli inceleme yaptığını; bazı SOC'lerin ise katmansız, uzmanlığa göre organize olduğunu öğrendim. L1'in işinin 'düşük değerli' görülmemesi gerektiğini, çünkü SOC'nin ilk ve en kritik filtresinin orası olduğunu kavradım. Event, Alert ve Triage kavramlarını çalıştım: event'in gözlemlenebilir herhangi bir şey, alert'in ise bir event'in potansiyel saldırı olabileceğini ima eden teknik bir bildirim olduğunu; bir alarmın gelmesinin tek başına kötü bir şey olduğu anlamına gelmediğini, gerçek anlamı çıkarmanın insan analizi gerektirdiğini öğrendim. Son olarak ground truth kavramını ve otomasyonun triyajı hızlandırdığını ama insan muhakemesinin yerini tam alamadığını kavradım. Ayrıca bu gün, ileride karşılaşacağım vakaları tutarlı ve standart bir biçimde kayıt altına alabilmek için kendi vaka defteri şablonumu hazırladım. Şablonda olay özeti ve kapsamı, zaman çizelgesi, bulgular ve kanıtlar (kanıt derecesi belirtilerek), etkilenen sistemler/hesaplar, MITRE ATT&CK eşleşmesi ile etki değerlendirmesi ve öneriler bölümlerini sabit bir yapıya oturttum; böylece her yeni vakada aynı düzeni tekrar kurmak yerine doğrudan analiz kısmına odaklanabileceğim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		15

<u>İş Yeri</u>nde Çalışılan Birim: IT Departmanı - Siber Güvenlik Birimi		Tarih: 08.09.2026 (Salı)
<u>Yapılan iş:</u> Alarm Kuyruğu Triyajı ve Emotet Vakası		
On ikinci günümde bir alarm kuyruğunu (9 alarm) triyaj ettim. Her alarm için karar (Gerçek Pozitif/Yanlış Pozitif/Veri Yetersiz), öncelik, aksiyon ve gerekçe belirledim. SSH brute force alarmını Case 1 bulgularıyla doğrulayarak Kritik/Gerçek Pozitif olarak eskale ettim; buna karşılık bir servis hesabının mesai dışı SSH girişini bilinen bir yedekleme sunucusundan ve beklenen saatte olduğu için Yanlış Pozitif olarak kapattım. Credential dumping ve Office uygulamasının mshta.exe başlatması alarmlarını Case 2 bulgularıyla ilişkilendirip Case 2 vakasına bağladım. Büyük giden veri transferi alarmını 'olası Gerçek Pozitif' olarak işaretledim, çünkü db_dump.tgz ile zamansal örtüşme vardı ama bağlantıyı kanıtlayan bir process kaydı yoktu. Bir DNS tünelleme alarmında, 'durmuş' notunun tehdidin bittiği değil, saldırganın DNS kanalını kapatıp LSASS erişimine geçtiği an olduğunu Case 2 zaman çizelgesiyle ilişkilendirerek yorumladım. Ayrıca bir endpoint process injection alarmını, kaynak süreç adı ve erişim maskesi alanları boş geldiği için Veri Yetersiz olarak işaretleyip ek kaynak istedim. Son olarak kuyrukta içinde makro barındıran bir Office eki (fatura.doc) yer alan bir e-posta güvenliği alarmı vardı. Bu alarmı değerlendirmek için o gün CISA/FBI'nın Emotet danışma belgesini okudum; belgede tarif edilen dağıtım desenleriyle (ikna edici, genelde mevcut bir e-posta zincirine (thread hijacking) eklenen makrolu Office ekleri üzerinden yayılma) karşılaştırdım; alarmdaki ekin ve göndericinin bilinen Emotet göstergeleriyle birebir eşleşmediğini, ancak aynı sosyal mühendislik ve dağıtım tekniğini kullandığını belirledim. Bu benzerliğe dayanarak alarmı önlem amaçlı Gerçek Pozitif olarak işaretleyip ekin sandbox'ta patlatılmasını (detonation) önerdim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		16

<u>İş Yerinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 09.09.2026 (Çarşamba)
<u>Yapılan iş:</u> Gerçek Phishing E-postası Analizi		
On üçüncü günümde üç gerçek phishing e-postasını analiz ettim. Birinde (sahte Microsoft hesap uyarısı) başlık zincirindeki Return-Path ile From adreslerinin farklı olduğunu, spf=none/dkim=none/dmarc=permerror ile hiçbir doğrulamanın geçmediğini; mailin görünürdeki butonlarının aslında saldırıyanın Gmail adresine giden mailto linkleri olduğunu buldum. İkincisinde (sahte Trustwallet uyarısı) SPF ve DKIM'in geçmesine rağmen DMARC'ın 'fail' verdiğini; bunun, imzalayan domain ile kullanıcının gördüğü From domaininin hizalı olmamasından kaynaklandığını, yani 'pass' görmenin tek başına yeterli olmadığını kavradım. Üçüncüsünde saldırıyanın ücretsiz bir Microsoft 365 kiracısı açarak gerçek Microsoft altyapısından mail gönderdiğini, gövdede istatistiksel spam filtrelerini şaşırtmak için tekrar eden dolgu metni ve Yunanca omicron kullanan bir homoglyph hilesi bulunduğunu tespit ettim. Üç örneğin ortak dersini çıkardım: spf/dkim/dmarc 'pass' görmek asla tek başına yeterli değil; karar her zaman Return-Path ile From'un karşılaştırılmasına ve linkin gerçek nihai hedefinin takip edilmesine dayanmalı. IOC zenginleştirmesinde her üç örneğin hedef adres/IP'lerini VirusTotal ve AbuseIPDB'de sorgulayarak itibar bilgilerini kaydettim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		17

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 10.09.2026 (Perşembe)
<u>Yapılan iş:</u> Malware Statik Analizi (AgentTesla) ve YARA		
On dördüncü günümde MalwareBazaar'dan alınan gerçek bir kötücül yazılım örneğini (AgentTesla ailesi, .docm dosyası) statik olarak analiz ettim. Belgenin Document_Open makrosuyla otomatik tetiklendiğini, MSXML2.XMLHTTP ile bir PowerShell scripti indirip gizli pencerede çalıştırdığını oleid ve olevba araçlarıyla ortaya çıkardım. olevba'nın kaynak kod ile derlenmiş p-code arasında bir isim uyumsuzluğu (VBA stomping şüphesi) tespit ettim; davranışın her iki gösterimde de birebir aynı kaldığını, bu yüzden isim uyumsuzluğunun davranışı değiştirmedeğini ama statik tarama araçlarını şaşırtmak için kullanılmış olabileceğini kavradım. any.run sandbox raporunun 'tehdit tespit edilmedi' sonucunu statik analizimle karşılaştırdım: sandbox'ın belgeyi bozuk sanıp makroyu hiç tetiklemediğini fark ettim - bu bana sandbox skorunun tek başına yeterli olmadığını gösterdi. Bulgularımı bir IOC listesi ve MITRE ATT&CK eşlemesiyle (T1204.002, T1059.005, T1105, T1059.001, T1027) belgeledim. Son olarak örneğe ve iki ayrı temiz metne karşı test ettiğim bir YARA kuralı yazarak vaka kaydını tamamladım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		18

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 11.09.2026 (Cuma)
<u>Yapılan iş:</u> Sigma Kuralları, Tespit Mühendisliği ve Volt Typhoon Danışma Belgesi		
On beşinci günümde Sigma kurallarını ve tespit mühendisliğini çalıştım. Sigma'nın, bir tespit kuralını SIEM'den bağımsız yazıp istenen SIEM'in diline çevirmeyi sağlayan standart bir format olduğunu; YARA'nın dosya desenlerine, Sigma'nın log desenlerine baktığını kavradım. Case 2'de bulduğum üç davranışı (mshta.exe başlatma, kodlanmış PowerShell, lsass.exe'ye şüpheli erişim) Sigma kurallarına daktım; süreç oluşturma için Sysmon EventID 1'e, süreç erişimi için EventID 10'a bakılması gerektiğini belirledim. sigma-cli ile kuralları -p sysmon pipeline'ıyla Splunk SPL'ine çevirdim; ilk denemede sorgu boş döndü, çünkü çevrilen sorguda index=case2 eksikti, bunu kendim ekledim. Aynı kuralı -p splunk_windows ile de çevirip karşılaştırdım: bu kez Splunk'ın kendi Windows alanlarıyla üretildiği için verimle uyuşmadı. Bu karşılaştırma, pipeline'ın Sigma'nın genel log kaynağı adını belirli bir ürünün Event ID'sine çeviren köprü olduğunu, Gün 18'deki normalleştirme kavramının pratik karşılığı olduğunu gösterdi. Doğru pipeline ve index bilgisiyle bir kuralı çalışır hale getirdim. Case 2 için kısa bir olay sonrası değerlendirme notu yazdım: hangi kuralın olayı hangi anda yakalayacağını, görünürlük boşluklarımın hangi log kaynağıyla kapanabileceğini ve bir sonraki vakada ilk gün uygulayacağım dersi (veri kaynaklarının alan şemasını önce kontrol etmek) belirledim. Son olarak CISA'nın Volt Typhoon danışma belgesini (AA24-038A) inceleyip bir davranış için ek bir Sigma kural taslağı yazdım; devlet destekli bir grubun aynı "living off the land" mantığını farklı bir amaçla nasıl kullandığını görmek, Pyramid of Pain'in davranış katmanının değerini somutlaştırdı.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		19

<u>İş Yerinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 14.09.2026 (Pazartesi)
<u>Yapılan iş:</u> Case 3: Phishing E-postası ve Zararlı ISO Eki (YARA Kuralı)		
On altıncı günümde yeni ve son vakam olan Case 3'ü açtım: satın alma departmanından s.yilmaz'ın bildirdiği, tedarikçi ödeme dekontu görünümlü bir e-posta ve içindeki ISO eki. Bu vakada geçen haftanın tüm araçlarını yönlendirme almadan, kendi kararımla bir araya getirmem gerekiyordu. Önce e-postayı lab kurallarına uygun şekilde (araçları ağ açıkken kurup snapshot alarak, VM içinden indirip hash doğrulayarak, sonra ağı keserek) inceledim; eml-ozet.py ile başlık zincirini çıkardım ve SPF/DKIM/DMARC'ın üçünün de başarısız olduğunu, gönderen IP'nin moss.it'in yetkili sunucusu olmadığını buldum. Eki file ve 7z l ile çalıştırmadan inceledim: quotation.iso adlı bir ISO 9660 imajı, içinde VB6 tabanlı bir crypter/dropper (TRAPFALL.exe). strings taramasında MSVBVM60.DLL/VBA6.DLL izlerinin yanında anlamsız dolgu kelimeleri buldum; bunu bir builder aracının imza tabanlı tespiti zorlaştırma girişimi olarak değerlendirdim. Her iki dosyayı da ana makineden VirusTotal'da sorguladım: ISO 40/61, EXE 61/72 motor tarafından Andromeda/Gamarue ailesi olarak işaretlenmişti. Bu makineden hiç Sysmon/Security/ağ logu toplanmadığı için "kullanıcı gerçekten bir şey çalıştırdı mı" sorusunu yalnızca kullanıcı beyanı ve VirusTotal'ın davranış etiketleriyle (checks-user-input, long-sleeps, detect-debug-environment) cevaplayabildim; bunu OBSERVED değil INFERRED olarak işaretleyip iş istasyonunu düşük kesinlikle de olsa "ele geçirilmiş sayılmalı" kategorisine koydum. Bulgularımı Gün 31'deki vaka defteri şablonuma işledim: gözlemler, IOC tablosu, MITRE eşlemesi (T1566.001, T1204.002, T1036, T1027, T1497, T1047), karar (Kritik/Gerçek Pozitif), kullanıcıya gidecek bildirim metni ve iş istasyonu için somut aksiyonlar (izolasyon, parola sıfırlama, L2'ye devir). Son olarak tespit kuralı için Sigma yerine YARA'yı seçtim, çünkü bu makineden hiç log toplanmadığından bir Sigma kuralı test edilemeden kağıt üzerinde kalırdı; elimdeki tek somut artefakt dosyanın kendisiydi. VB6 imzalarını tek başına yeterli görmeyip bunlara builder'ın ürettiği nadir dolgu kelimelerinden en az ikisini şart koşan bir kural yazdım; kuralı gerçek örneğe karşı çalıştırıp eşleştiğini, temiz bir test metnine karşı çalıştırıp eşleşmediğini doğruladım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		20

<u>İş Yerinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 15.09.2026 (Salı)
<u>Yapılan iş:</u> Case 3 Olay Raporu: Yönetici Özeti ve Teknik Ek		
On yedinci günümde Case 3'ün son raporunu, iki farklı okuyucu için tek dosyada yazdım. Yönetici özetini yaklaşık üç yüz kelimeyle, hiçbir teknik terim (IP, hash, Event ID, MITRE kodu) kullanmadan yazdım; sadece üç soruyu cevapladım: ne oldu, ne risk altında, ne yapılmalı. Emin olmadığım noktaları burada da 'kesin değil' diye belirttim. Yazdıktan sonra sayfayı teknik geçmişini olmayan biriymiş gibi okuyarak test ettim; ilk okumada üç soruya da cevap verebildiğimi görünce sayfayı tamamlanmış saydım. Teknik eki dünkü vaka kaydımdan türeterek yazdım. Rapor başına TLP etiketini ekledim; e-postanın kendi başlık tarihlerini, ekten elde ettiğim zaman damgalarını ve kullanıcı beyanındaki saatleri tek bir zaman çizelgesi tablosunda, saat sırasına göre yan yana koydum - farklı kaynaklardan gelen bu zamanları aynı tabloda görmek, aradaki tutarsızlığı (e-postanın başlık tarihinin bağlamla uyuşmaması gibi) çok daha net gösterdi. Kanıtları gözlem/çıkarım/bilinmiyor derecelendirmesiyle, IOC'leri etkisizleştirilmiş biçimde, ATT&CK eşlemesini teknik ID'leriyle ve dünkü YARA kuralımı sonucuyla birlikte ekledim. Önerilerimi kök nedene yönlendirdim: e-postanın neden kullanıcıya ulaştığı, ekin neden açılabilirdiği, bir dahaki sefere hangi kontrolün bunu durduracağı. Bu makineden hiç log toplanmamasını da ayrı bir görünürlük boşluğu bulgusu olarak yazdım. Raporu bitirdikten sonra Case3-Ölçüt.md'deki on bir soruyu tek tek kendime sorup öz denetim yazdım; hangi maddelere 'eksik' dediğimi ve zaman kısıtı nedeniyle neden düzeltmediğimi üç satırla belirttim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		21

<u>İş Yerinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 16.09.2026 (Çarşamba)
<u>Yapılan iş:</u> Tespit Kuralları Deposu (Tespit-Kurallari/)		
On sekizinci günümde staj boyunca yazdığım tüm tespit kurallarını tek bir Tespit-Kurallari/ klasöründe topladım. Gün 34'ün YARA kuralını, Gün 35'in üç Sigma kuralını, Volt Typhoon okumasından çıkan taslağı ve Case 3'ün YARA kuralını kendi dosyalarına (.yaml ve .yar) anlaşılır adlarla ayırdım; daha önce yalnızca günlük notlarımın içinde metin olarak duran kurallar bugün gerçekten kopyalanıp çalıştırılabilir dosyalara dönüştü. Klasöre bir README.md yazdım: her kural için hangi davranışı yakaladığını, hangi log kaynağına (Sysmon EventID, dosya) baktığını ve bir yanlış pozitif notunu üç satırla belirttim. Her kuralın test durumunu da (Case 2 verisinde çalıştırılıp yakaladı, yalnızca sigma-cli ile doğrulandı, ya da taslak/hiç test edilmedi) ayrı ayrı etiketledim. Kuralları yanlış pozitif gözüyle tekrar okuyunca, PowerShell kuralımın meşru yönetsel betiklerde de tetiklenebileceğini fark ettim; bunu dışlayan bir filtre ekleyip README'de gerekçesini yazdım. Tüm .yaml dosyalarını sigma check ile bir kez geçirdim ve sonucu README'ye tek satırla not ettim. Ayrıca Hafta 7 notumda işaretlenmiş düzeltmeleri kapattım: ilgili günlerin dosyalarında gerekli düzeltmeleri yaptım ve her birini o günün klasörüne birer satırla not ettim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		22

<u>İş Yerinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 17.09.2026 (Perşembe)
<u>Yapılan iş:</u> Repo README'si ve Portfolyo Düzenlemesi		
On dokuzuncu günümde reponun kök README'sini baştan yazdım; hem teknik hem teknik olmayan bir okuyucuya hitap edecek şekilde stajın süresini, odağını ve kullandığım araçları birkaç cümleyle özetledim. Üç vakanın (Case 1, Case 2, Case 3) birer cümlelik özetini yazıp raporlarına bağlantı verdim, Tespit-Kuralları/ klasörüne bağlantı ekledim ve reponun nasıl gezileceğini (günlük klasörler, engel kayıtları, log envanteri) kısaca anlattım. Kişisel bilgi koymadım, yalnızca adımları ekledim. Vakalardaki kurum, kişi ve sistem adlarının kurgu olduğunu, gerçek e-posta ve zararlı örneklerinin herkese açık araştırma depolarından alındığını ve reponun hiçbir gerçek kurum verisi içermediğini belirten tek cümlelik notu da ekledim. Haftalar.md dosyasını oluşturup sekiz haftanın her biri için tek cümlelik bir özet yazdım; bunu yazabilmek için ilk haftaların notlarını tekrar açıp okudum, başladığım yerle geldiğim yer arasındaki farkı bu şekilde kendi gözümle gördüm. Son olarak reponun ayıklamasını yaptım: boş klasörleri, aynı dosyanın birebir kopyalarını ve yanlış klasöre düşmüş ekran görüntülerini temizledim. Hiçbir taslağı silmedim, çünkü her biri bir günün kanıtıydı; sadece adlarının ne olduklarını netleştirdim. Her dosyayı silmeden önce 'bu bir bulgunun kanıtı mı' sorusunu sorarak karar verdim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		23

<u>İş Yerinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 18.09.2026 (Cuma)
<u>Yapılan iş:</u> Pusula: Stajdan Çıkarımlar ve Sonraki Adımlar		
Yirminci ve staj-2'nin son günü, sekiz haftalık süreci bir müfredatla değil kendi yazacağım bir değerlendirme metniyle kapatmam gerekiyordu. Önce, staj sonrası hangi yönde ilerleyebileceğimi gösteren, her biri için ücretsiz kaynaklar ve tek bir ilk adım öneren bir kaynak metnini okudum; bu metin beş farklı olası yönü (SIEM ve olay müdahalesi, ortalama analizi ve tehdit istihbaratı, tespit mühendisliği, zararlı yazılım triyajı, komut satırı ve küçük araçlar) özetliyordu. Ardından kişisel değerlendirme yazımı iki bölüm halinde hazırladım. 'Bu stajdan ne götürüyorum' bölümünde en çok öğrendiğim şeyin bir SOC'un gerçekte ne yaptığı (dağınık kaynaklardan gelen parçaları birleştirip bir olayın hikâyesini çıkarmak, sonra bunu test edilebilir hale getirip raporlamak) olduğunu yazdım. En çok öğreten hatamı somut bir örnekle anlattım: son vaka çalışmamda gönderen e-posta adresini ve IP adresini ilk incelememde hiç sorgulamadan 'kapsam dışı' diye geçmiştım; rapor aşamasında bunu tamamlayınca ikisinin de gerçek şirketlerin kimliğini taklit ettiğini ve gönderen IP'nin en az on farklı zararlı dosyada daha kullanıldığını buldum. Bu bana bir göstergeyi sorgulamadan geçmenin asıl hikâyeyi kaçırmak olduğunu öğretti. Kalıcı bir refleks olarak, artık kendi gündelik hayatımda bile bir mail geldiğinde ekine veya linkine tıklamadan önce gönderen adına ve mailin amacına dikkat ettiğimi yazdım. 'Altı ay sonra' bölümünde olay müdahalesi ve SIEM çalışmaları ile ortalama/tehdit istihbaratı analizi arasında kaldığımı, ikisini de bir vaka çözme tatmini üzerinden sevdiğimi belirttim. İleride kendime soracağım üç soruyu (hangi alana daha fazla ağırlık verdim, elle tutulur bir ilerleme var mı, hangi kaynağı düzenli takip etmeye devam ediyorum) yazıp metnin sonuna bunu altı ay sonra tekrar okumak üzere bir hatırlatma notu ekledim ve takvimime bunun için bir hatırlatma koydum. Son olarak staj boyunca çalışmalarımı kayıt altına aldığım GitHub deposunu son kez güncelleyip 'staj sonu' olarak tag'ledim. Sekiz hafta önce ilk gün notunu yazarak başladığım bu süreci, bugün bir olayı baştan sona çözüp hem teknik hem teknik olmayan bir okuyucuya anlatabilecek noktada tamamladım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		24

